

PLAN DE FORMACIÓN — BLUE TEAM

12 Semanas · Coste 0€ · Formato Cuaderno de Clase

Estudiante: Daniel (Responsable de IT, SD Distribuciones)

Objetivo: Pasar de «administro herramientas de seguridad» a «soy analista de seguridad» con evidencia pública que lo demuestre.

Repositorio de Clase: github.com/<tu-user>/blueteam-lab

Entorno de Prácticas: Producción Real (Wazuh, FortiGate, M365, DC 2012 R2, 80 PDAs)

ÍNDICE DE LA MATERIA

- **Bloque 1: ATT&CK y modelo mental (Semanas 1-3)**
 - Semana 1: Fundamentos ATT&CK
 - Semana 2: Mapeo de tu cobertura real
 - Semana 3: Modelos de detección
- **Bloque 2: Sigma: escribir detecciones (Semanas 4-6)**
 - Semana 4: Sintaxis y anatomía
 - Semana 5: Reglas de tu propia infra
 - Semana 6: Validación y afinado
- **Bloque 3: DFIR e investigación (Semanas 7-9)**
 - Semana 7: Análisis de tráfico
 - Semana 8: Casos reales de intrusión
 - Semana 9: Forense práctico
- **Bloque 4: Threat hunting proactivo (Semanas 10-12)**
 - Semana 10: Metodología
 - Semana 11: Cazas dirigidas
 - Semana 12: Cierre y empaquetado

Bloque 1 · ATT&CK y modelo mental (semanas 1-3)

Sin esto, todo lo demás es ruido. ATT&CK es el idioma común del blue team.

Semana 1 — Fundamentos ATT&CK

- **Concepto clave:** Leer la matriz Enterprise completa. No memorizar: entender la lógica del flujo — Initial Access → Execution → Persistence → Privesc → Defense Evasion → Credential Access → Discovery → Lateral Movement → Collection → C2 → Exfiltration → Impact.
- **Recursos:** attack.mitre.org + ATT&CK Navigator (gratis, en navegador).
- **Ejercicio:** Mapea el ataque de fuerza bruta IPv6 contra tu tenant M365. Spoiler: T1110 (Brute Force), probablemente T1110.003 (Password Spraying). ¿Qué habría venido después si hubiera tenido éxito? T1078 (Valid Accounts), T1114 (Email Collection)...

- **Entregable:** writeups/01-bruteforce-ipv6-m365.md — el incidente real: ASNs, volumetría, timeline, técnicas ATT&CK y mitigación aplicada. Es tu writeup estrella, dedícale tiempo.

ESPACIO DE APUNTES DE CLASE: SEMANA 1

Semana 2 — Mapeo de tu cobertura real

- **Concepto clave:** Exporta las reglas activas de Wazuh. Para cada una: ¿qué técnica ATT&CK cubre?
- **Ejercicio:** Monta una capa en ATT&CK Navigator. Verde = detecto. Amarillo = detecto parcial. Rojo = ciego. Vas a descubrir que estás ciego en Lateral Movement y Persistence. Todo el mundo lo está. Ese es el punto del ejercicio.
- **Entregable:** coverage/wazuh-attack-coverage.json (capa del Navigator) + un README con los 5 gaps más críticos en tu contexto concreto (DC en 2012 R2, RDP masivo desde PDAs Android...).

ESPACIO DE APUNTES DE CLASE: SEMANA 2

Semana 3 — Modelos de detección

- **Concepto clave:** Pyramid of Pain (David Bianco). Un artículo, 10 minutos, te reordena la cabeza: por qué detectar un hash es inútil y detectar TTPs es oro.
- **Plantilla industrial:** Alerting and Detection Strategy (ADS) de Palantir. Gratis en GitHub. Es la plantilla para escribir detecciones que no son basura.
- **Entregable:** docs/detection-philosophy.md — tu criterio propio: qué detectas, qué ignoras conscientemente, cuál es tu tolerancia a falsos positivos y por qué.

ESPACIO DE APUNTES DE CLASE: SEMANA 3

Bloque 2 · Sigma: escribir detecciones (semanas 4-6)

Aquí se produce el salto de nivel. Consumir alertas lo hace cualquiera. Escribirlas es lo que te contrata.

Semana 4 — Sintaxis y anatomía

- **Concepto clave:** Repo SigmaHQ. Lee 20-30 reglas antes de escribir la primera. Fíjate

en logsource, detection, condition, falsepositives, level.

- **Herramientas:** Instala sigma-cli (gratis) y convierte reglas a formato Wazuh / Elastic para ver el output.
- **Ejercicio:** Escribe tu primera regla, algo trivial: creación de usuario local en un servidor Windows (T1136.001).

ESPACIO DE APUNTES DE CLASE: SEMANA 4

Semana 5 — Reglas de tu propia infra

- **Casos reales de SD Distribuciones:** Escribe reglas Sigma para casos reales tuyos. Mínimo 5. Ideas con tu entorno:
 - Logon RDP desde IP fuera del rango de almacén (las PDAs tienen rango conocido) → T1021.001
 - Creación de servicio nuevo en SDSRV01 — DC EOL, ahí no debería crearse nada → T1543.003
 - Volumen anómalo de sesiones RDP concurrentes → anomalía operativa y posible abuso
 - Autenticación M365 desde ASN no habitual → T1078.004
 - Ejecución de PowerShell codificado en base64 en cualquier servidor → T1059.001
 - Modificación de reglas de FortiGate fuera de ventana de cambios → T1562.004
- **Documentación honesta:** Con falsepositives documentados: una regla sin FPs documentados es una regla que no has probado.

ESPACIO DE APUNTES DE CLASE: SEMANA 5

Semana 6 — Validación y afinado

- **Proceso:** Despliega las reglas en Wazuh. Mide FPs durante 7 días reales. Afina. Documenta qué afinaste y por qué. Este paso es el que separa a un junior de alguien con criterio.
- **Entregable del bloque:** sigma-rules/ con 5-10 reglas + README con contexto, FPs encontrados, tuning aplicado y métricas (alertas/día antes y después).

ESPACIO DE APUNTES DE CLASE: SEMANA 6

Bloque 3 · DFIR e investigación (semanas 7-9)

Ahora que sabes detectar, aprende a investigar cuando algo salta.

Semana 7 — Análisis de tráfico

- **Recursos:** Malware-Traffic-Analysis.net: coge 3 pcaps del archivo y resuélvelos con

Wireshark.

- **Objetivo:** Reconocer patrones de C2, beaconing y exfiltración por DNS.
- **Entregable:** writeups/02-pcap-analysis.md — un caso resuelto, con tu razonamiento, no solo la respuesta.

 **ESPACIO DE APUNTES DE CLASE: SEMANA 7**

Semana 8 — Casos reales de intrusión

- **Recurso principal:** The DFIR Report: escoge un caso parecido a tu superficie de ataque (RDP, AD o ransomware en entorno Windows).
- **Ejercicio de autoevaluación:** Léelo entero. Luego responde por escrito: ¿lo habría detectado yo? ¿En qué punto de la kill chain? ¿Con qué regla? ¿Qué log me falta? Un caso por semana, para siempre.
- **Entregable:** writeups/03-dfir-report-gap-analysis.md

 **ESPACIO DE APUNTES DE CLASE: SEMANA 8**

Semana 9 — Forense práctico

- **Recursos prácticos:** CyberDefenders: 2 retos gratuitos (Endpoint Forensics o Threat Hunting van perfectos). LetsDefend free tier: pasa los casos de SOC que te dejen. Cronométrate.
- **Herramientas base:** Volatility (memoria), Autopsy, Event Viewer avanzado y Sysmon — instálalo en un servidor de test tuyo, es gratis y cambia el juego de la visibilidad.
- **Entregable:** writeups/04-<nombre-reto>.md

 **ESPACIO DE APUNTES DE CLASE: SEMANA 9**

Bloque 4 · Threat hunting proactivo (semanas 10-12)

El nivel donde deja de importar si alguien te avisa o no.

Semana 10 — Metodología

- **El ciclo:** Hipótesis → datos → búsqueda → resultado → nueva detección (o descarte). Material gratis de SANS y el Threat Hunting Loop de Sqrrl.
- **Primera caza real:** «¿hay persistencia no autorizada en mis servidores?» Revisa tareas programadas, servicios, claves Run y suscripciones WMI. Con un DC de 2012 R2, prepárate para encontrar cosas raras.

 **ESPACIO DE APUNTES DE CLASE: SEMANA 10**

Semana 11 — Cazas dirigidas

- **Escenarios de caza:**
 - Alguien ha usado credenciales válidas fuera de horario para acceder a recursos que no le tocan (logs M365 + RDP).
 - Hay un binario ejecutándose desde una ruta de usuario o temp en algún servidor.
 - Alguna PDA está haciendo algo que no debería. Tienes 80: alguna hará ruido.
- **Regla de oro:** Documenta todas, incluidas las que salgan vacías. Un hunt negativo bien documentado demuestra método.

 **ESPACIO DE APUNTES DE CLASE: SEMANA 11**

Semana 12 — Cierre y empaquetado

- **Tareas finales:** README principal del repo: quién eres, qué hay dentro, qué demuestra cada cosa. LinkedIn: publica el writeup del brute force IPv6. Contenido real, con datos, de un incidente que gestionaste tú. Eso genera conversaciones. Compara la capa de ATT&CK Navigator de la semana 2 con la de ahora. La diferencia visual es tu progreso.
- **Entregable:** Repo público presentable + 1 publicación en redes.

 **ESPACIO DE APUNTES DE CLASE: SEMANA 12**

Recursos (todos gratis)

Qué	Dónde	Para qué
MITRE ATT&CK + Navigator	attack.mitre.org	Framework base
SigmaHQ	github.com/SigmaHQ/sigma	Reglas de detección
The DFIR Report	thedfirreport.com	Intrusiones reales
Malware Traffic Analysis	malware-traffic-analysis.net	Pcaps para analizar
CyberDefenders	cyberdefenders.org	Retos DFIR (free tier)
LetsDefend	letsdefend.io	Simulador de SOC (free tier)

Qué	Dónde	Para qué
Antisyphon PWYC	antisyphontraining.com	Cursos pro (paga 0€ si quieres)
Sysmon + SwiftOnSecurity	github.com/SwiftOnSecurity/sysmon-config	Visibilidad Windows
Atomic Red Team	github.com/redcanaryco/atomic-red-team	Probar tus detecciones

Reglas del juego

- **Publicar > estudiar.** Si una semana solo te da para escribir el writeup y no para el lab, escribe el writeup.
- **Nada de coleccionar cursos.** No abras un curso nuevo hasta terminar el entregable actual.
- **Todo lo del trabajo se convierte en contenido.** Anonimizando siempre: nada de IPs internas reales, nombres de servidores ni datos de empleados.
- **Las certificaciones vienen después.** Con esto hecho, Security+ la sacas en 3 semanas y BTL1 la pasas sin sudar.

Aviso de honestidad: Este plan no te va a hacer analista de seguridad en 12 semanas. Te va a hacer alguien con evidencia demostrable de que piensa como analista de seguridad, que es lo que realmente hace falta para dar el salto. Un plan de 20 semanas terminado vale infinitamente más que uno de 12 abandonado en la semana 6.